

MTSC2025

中国互联网测试开发大会

TESTING SUMMIT CONFERENCE CHINA 2025

上海
站

质效革新·智领未来

2025/7/12 | 上海喜来登由由大酒店 主办方: TesterHome

MTSC2025 中国互联网测试开发大会 上海站
TESTING SUMMIT CONFERENCE CHINA 2025

AI驱动的APP行为合规监测

魏 兵

质效革新·智领未来

STONEHILL
岩山科技

主办方: TesterHome

章节目录

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站

- 01 背景与风险
- 02 收集行为数据
- 03 数据分析平台化
- 04 引入AI分析
- 05 具体实践落地收益

背景与风险

01

2019年 1 月:中共中央网络安全和信息化委员会办公室等四部门,联合发布《关于开展 App 违法违规收集使用个人信息专项治理的公告》,并成立专项治理工作组。

02

2019年 11 月:国家互联网信息办公室等四部门,联合制定《App 违法违规收集使用个人信息行为认定方法》,明确六大类违法违规行为认定方法。

03

2020年 10 月:《GB/T 35273-2020 信息安全技术个人信息安全规范》正式实施,细化个人信息处理环节合规要求。

04

2021年 11 月:《中华人民共和国个人信息保护法》正式实施,明确个人信息全生命周期合规要求。

05

2023年 5 月:《GB/T 42574-2023 信息安全技术 个人信息处理中告知和同意的实施指南》发布,细化告知同意实施要求。

06

2024年 3 月:工业和信息化部公布《移动应用软件个人信息保护要求和评估方法》(YD/T6221-2024),2025 年 4 月 1 日起实施。

07

2024年:公安部深入推进“净网”专项行动,侦破侵犯公民个人信息案件 7000 余起。

08

2025年 3 月:国家互联网信息办公室公布《个人信息保护合规审计管理办法》,5 月 1 日起施行。

信息收割雷

13款APP违规收集信息，面临15个工作日内整改，否则将遭受高达5000万罚款。

千款APP陨落

2024年，工信部严查违规APP，全年1712款需整改，506款被通报，78款遭下架。

数据裸奔

2025年Q1，17款APP中6款因向第三方提供“未匿名化数据”被全网下架。

合规问题面临的风险

无法过审

App 因隐私合规未达应用市场审核标准，无法通过审核上线。

用户投诉

用户发现 App 存在私自收集信息等隐私侵权行为，向监管部门、应用市场或运营方投诉。

行政处罚

监管部门依法律法规，对存在隐私合规问题的 App 运营主体予以罚款、警告等行政处罚。

应用下架

已上线 App 因隐私不合规，被监管部门或应用市场强制下架，停止提供下载服务。

法律诉讼

App 隐私侵权情节严重，遭用户或权益人诉至法院追责。

人工难以收集获取APP内部行为数据，政策迭代快、第三方 SDK 合规难同步，且第三方检测成本高。



主动检测

从被动到主动,提前
发现和处理相关风
险。



常态化监测

对合规状态进行常
态化监测,防止相同
隐私问题重复出现。

收集行为数据

重点检测的行为内容范围

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站

01

隐私合规

信息全流程(收集/处理/存储/分享)

02

设备信息

获取设备特征数据(间接关联用户身份)

03

个人信息

可识别个人身份的信息(直接/间接)

静态检测方案

1

Lint扫描检测

开发阶段监测隐私 API 调用,提前规避合规风险。

2

字节码扫描检测

扫描解析.class/.dex 文件,检查代码潜在合规风险。

3

smali扫描检测

dex反汇编smali 代码,逐行排查敏感操作。

4

反编译扫描检测

逆向代码检索,根据关键字搜索查找。

特性	Xposed	EdXposed	LSPosed	VirtualXposed
兼容性	Android 4.0 - 7.1	Android 8.0 - 11	Android 8.1-14	Android 5.0-10.0
Root需求	需要Root	需要Root、依赖 Magisk	需要Root、依赖 Magisk	不需要Root
稳定性	较高	相对稳定，但有时在 新系统不稳定	高，适合新系统	较低，功能受限
系统影响	需修改系统文件	无系统分区修改 依赖 Magisk	无系统分区修改 依赖 Magisk	独立环境，安全性高
维护	不再维护	不再维护	维护中	不再维护

借助 Riru 修改 Android 父进程 Zygote进程，通过 Hook 技术动态拦截应用方法调用，精准获取应用行为数据。

实现合规检测能力

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站

定制检测规则
勾选规则触发 Hook, 拦截方法时解析参数判定行为。

主体溯源判定
依据堆栈包名锁定行为触发主体。



结果可视化输出
Hook 方法触发即生成堆栈详情, 检测结果同步写入 Excel。

重载调用过滤
规避重载方法引发的重复调用干扰。



检测类别概览

覆盖39大类，71条规则，确保全方位监控，从个人信息与设备状态。



核心信息捕获

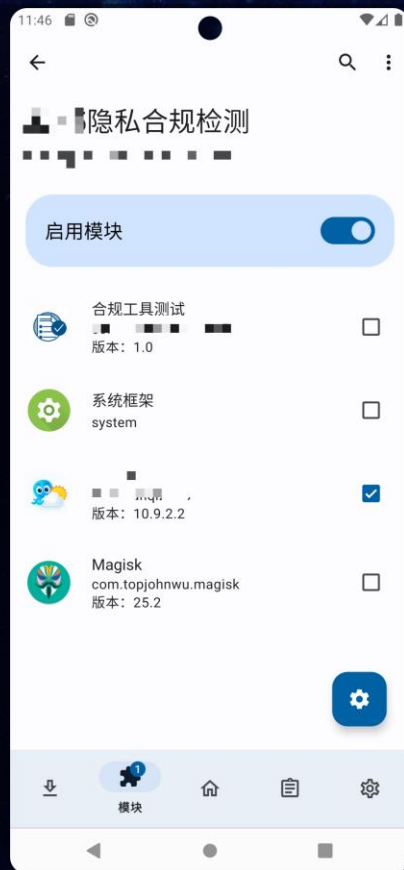
精准锁定设备序列号、Android ID、IMEI等标识符，确保数据安全合规。



系统层面洞察

深度监测应用列表、运行状态及权限使用，深度拆解收集APP行为模式。

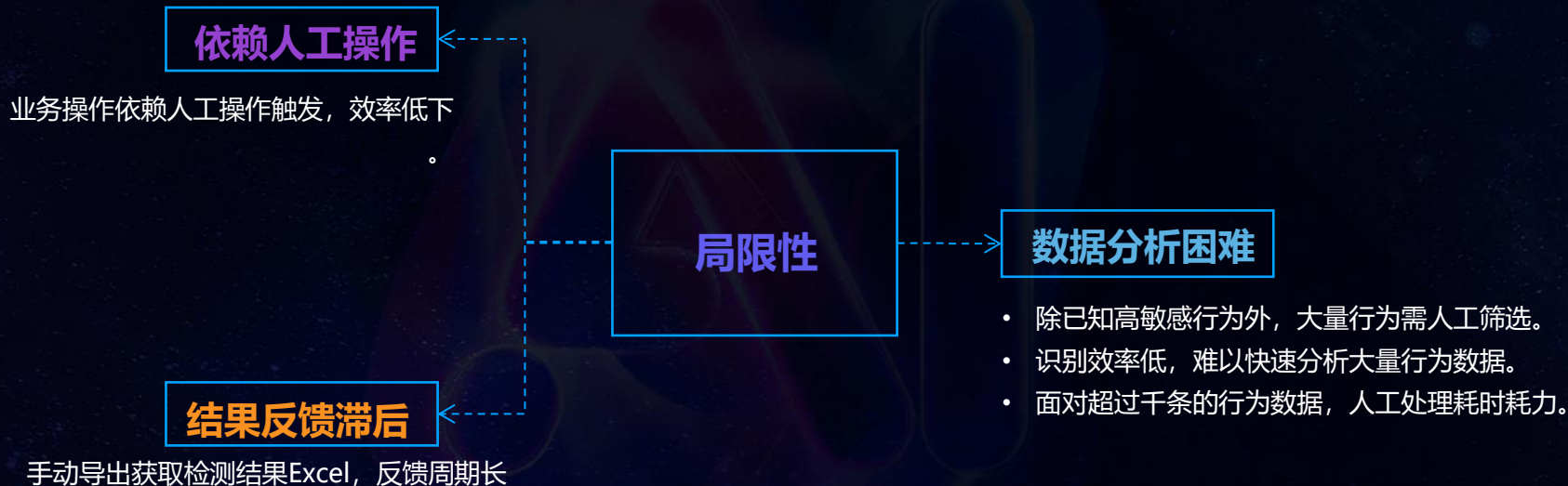
工具使用一览



检测结果示例

行为主体	行为分类	行为描述	触发进程	触发方法	方法参数	调用堆栈
	权限	检查权限	com	android.content.ContextWrapper#checkSelfPermission	参数1: android.permission.BLUETOOTH	WV.s4.c(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:5) org.chromium.media.AudioManagerAndroid.init(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:24)
	权限	检查权限	com	android.content.ContextWrapper#checkSelfPermission	参数1: android.permission.BLUETOOTH	android.content.ContextWrapper.checkSelfPermission(ContextWrapper.java:793) java.lang.reflect.Method.invoke(Native Method) org.isposed.ispd.nativebridge.HookBridge.invokeOriginalMethod(Native Method) LSPHooker.checkSelfPermission(Unknown Source:11) WV.s4.c(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:5) org.chromium.media.AudioManagerAndroid.init(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:24)
	移动网参数	获取移动网参数	com	android.net.ConnectivityManager#getActiveNetworkInfo		com.qq.e.comm.plugin.uttl.r0.e(A:6) yqq.pro.getVresult(Native Method) com.qq.e.comm.plugin.q0.a.e(Unknown Source:12) com.qq.e.comm.plugin.q0.a.a(A:8) com.qq.e.comm.plugin.q0.a.f(A:2) com.qq.e.comm.plugin.q0.l.\$c.run(A:4) android.os.Handler.handleCallback(Handler.java:914) android.os.Handler.dispatchMessage(Handler.java:100) android.os.Looper.loop(Looper.java:228) android.os.HandlerThread.run(HandlerThread.java:67)
	应用信息	获取指定应用信息-高敏	com	android.app.ApplicationPackageManager#getPackageInfo	参数1: com.google.android.gms 参数2: 64	WV.Qn.b(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:69) WV.Qn.a(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:32) WV.es.a(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:24) WV.a1.c(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:5) WV.a1.run(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:33)
	移动网参数	获取移动网参数	com	android.net.ConnectivityManager#getActiveNetworkInfo		com.qq.e.comm.plugin.uttl.r0.e(A:6) yqq.pro.getVresult(Native Method) com.qq.e.comm.plugin.q0.a.d(Unknown Source:12) yqq.pro.getVresult(Native Method) com.qq.e.comm.plugin.q0.a.e(Unknown Source:12) com.qq.e.comm.plugin.q0.a.a(A:8) com.qq.e.comm.plugin.q0.a.f(A:2) com.qq.e.comm.plugin.q0.l.\$c.run(A:4) android.os.Handler.handleCallback(Handler.java:914) android.os.Handler.dispatchMessage(Handler.java:100) android.os.Looper.loop(Looper.java:228) android.os.HandlerThread.run(HandlerThread.java:67)

检测工具的局限性



分析平台化

针对使用局限性探索优化方案

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站

引入智能遍历

通过APP智能遍历技术，智能分析遍历被测APP功能，替代人工触发行为数据。

引入AI分析

引入AI+知识库前置辅助行为分析，减少人工参与。

版本增量比较

提供版本行为比视图，快速识别版本增量行为。



实时数据上报

合规检测程序按照标识实时上报数据到质量平台，确保数据的及时性和准确性。

区分行为及时机

区分触发时机及授权状态，标记区分已知和未知行为。

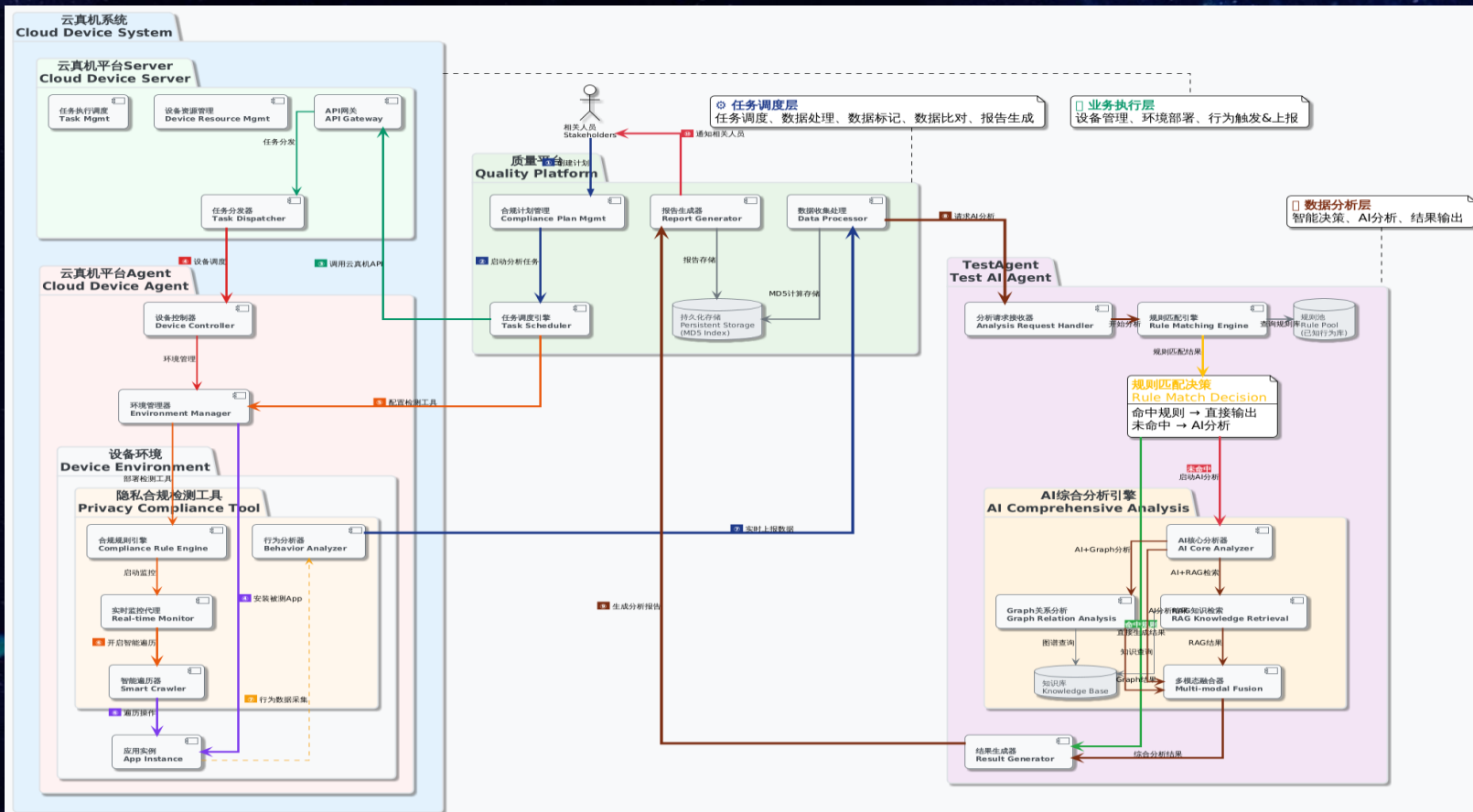
去重机制

根据上报数据中的关键字段统一计算MD5，方便后续去重后归类展示。

整体系统架构图

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

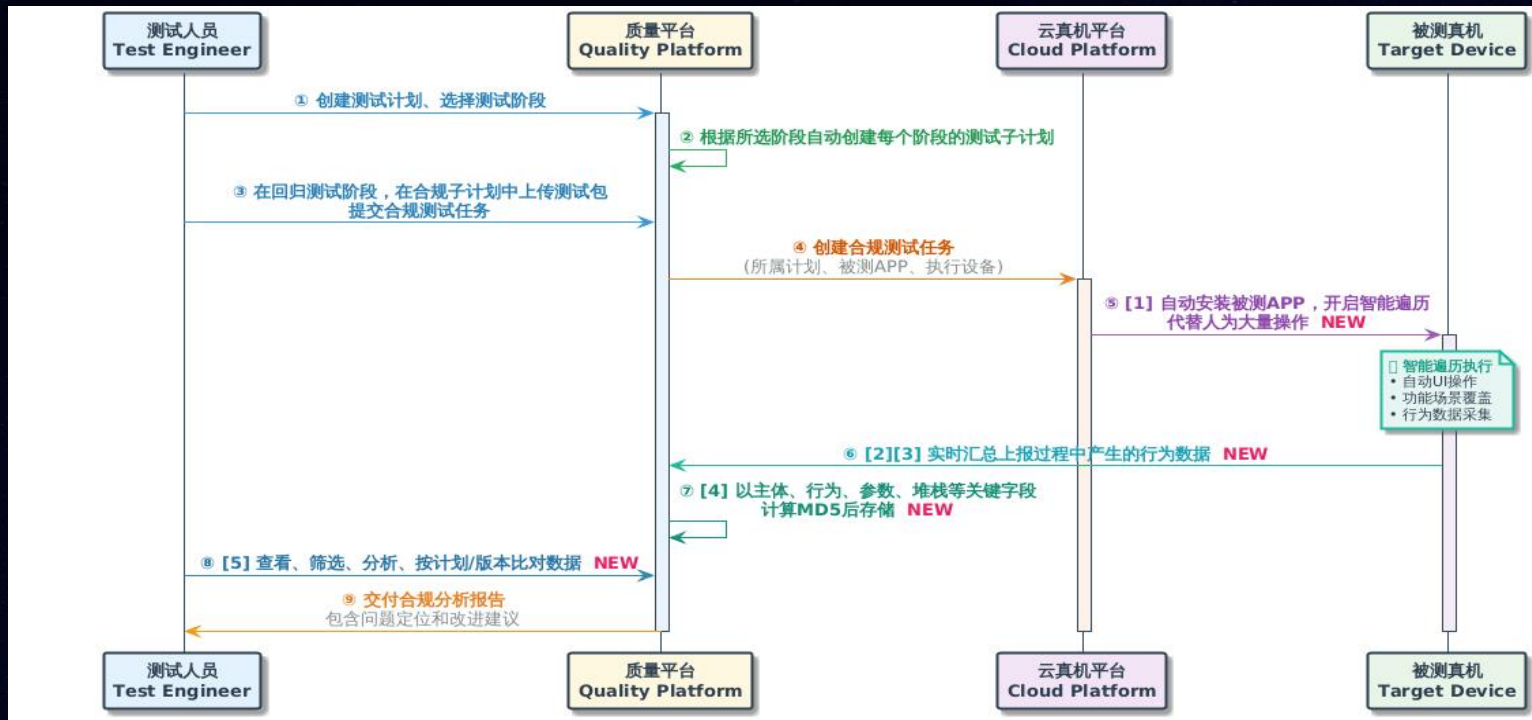
上海站



质效革新·智领未来

STONE HILL 岩山科技 主办方: TesterHome

平台化比对分析实施路径

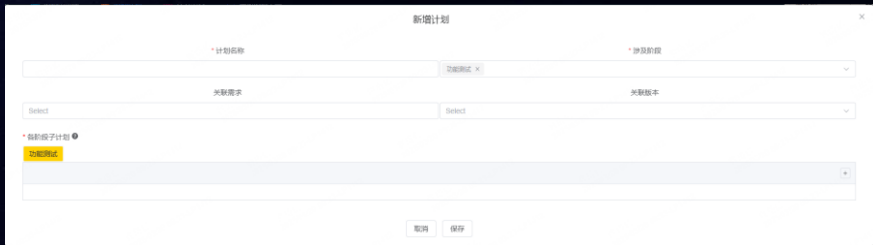


注: 当前智能遍历基于fastbot、appium二次开发整合精准测试平台覆盖率能力遍历评估智能遍历效果

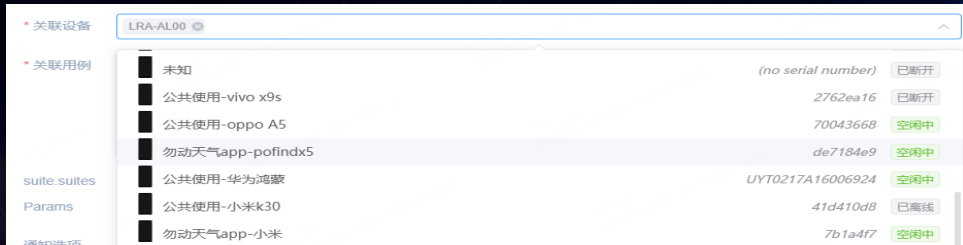
质效革新·智领未来

MTSC2025 中国互联测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

配置测试设备

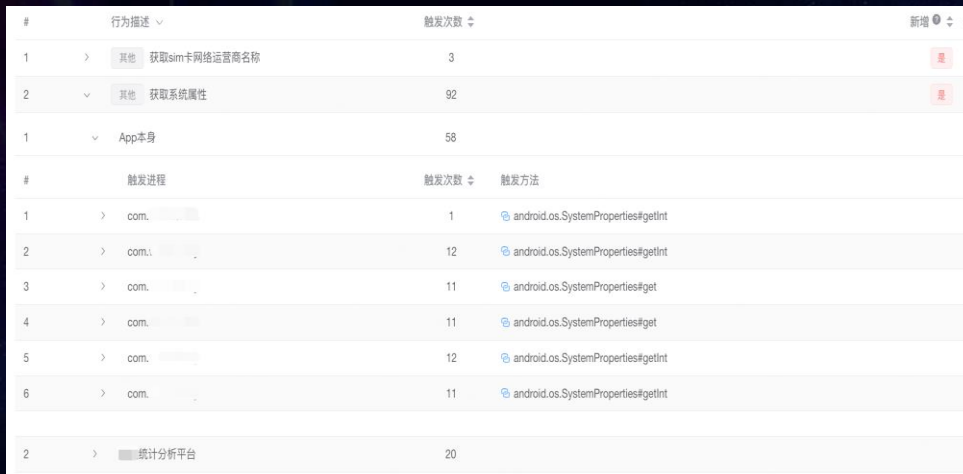


人员在测试平台创建新测试计划，生成唯一计划ID，确保链路回溯追踪



通过计划ID，配置设备准备接收并执行指定的APP测试任务

结果汇总视图



人工分析行为数据困境

1. **效率低**：去重比对后,仍有大量数据需人工逐条分析。
2. **易疏漏**：人员专业能力参差不齐,容易遗漏,且难以及时识别新出台的行业规范,存在合规风险。
3. **重复劳动与资源浪费**：无有效收敛机制，旧数据重复出现时难识别，浪费人力。

转向AI分析的解决方案

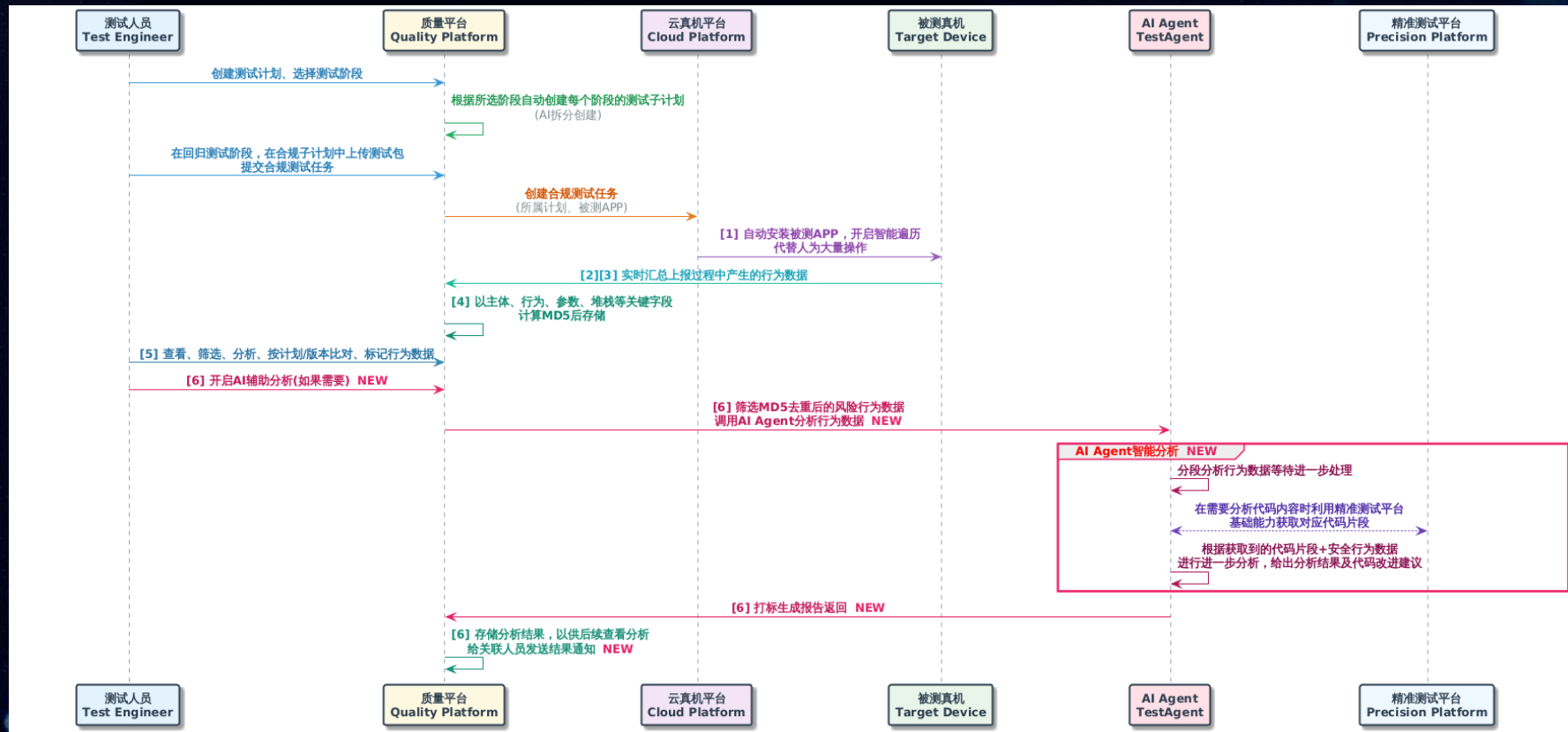
1. **AI 预筛 + 人工复核**：AI 智能筛选数据并分级，人工仅处理风险项，大幅降低工作量。
2. **构建规则库,阻断重复分析**：沉淀合规数据规则，过滤重复分析，实现数据处理的闭环优化。

引入AI分析

引入AI具体实施路径

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

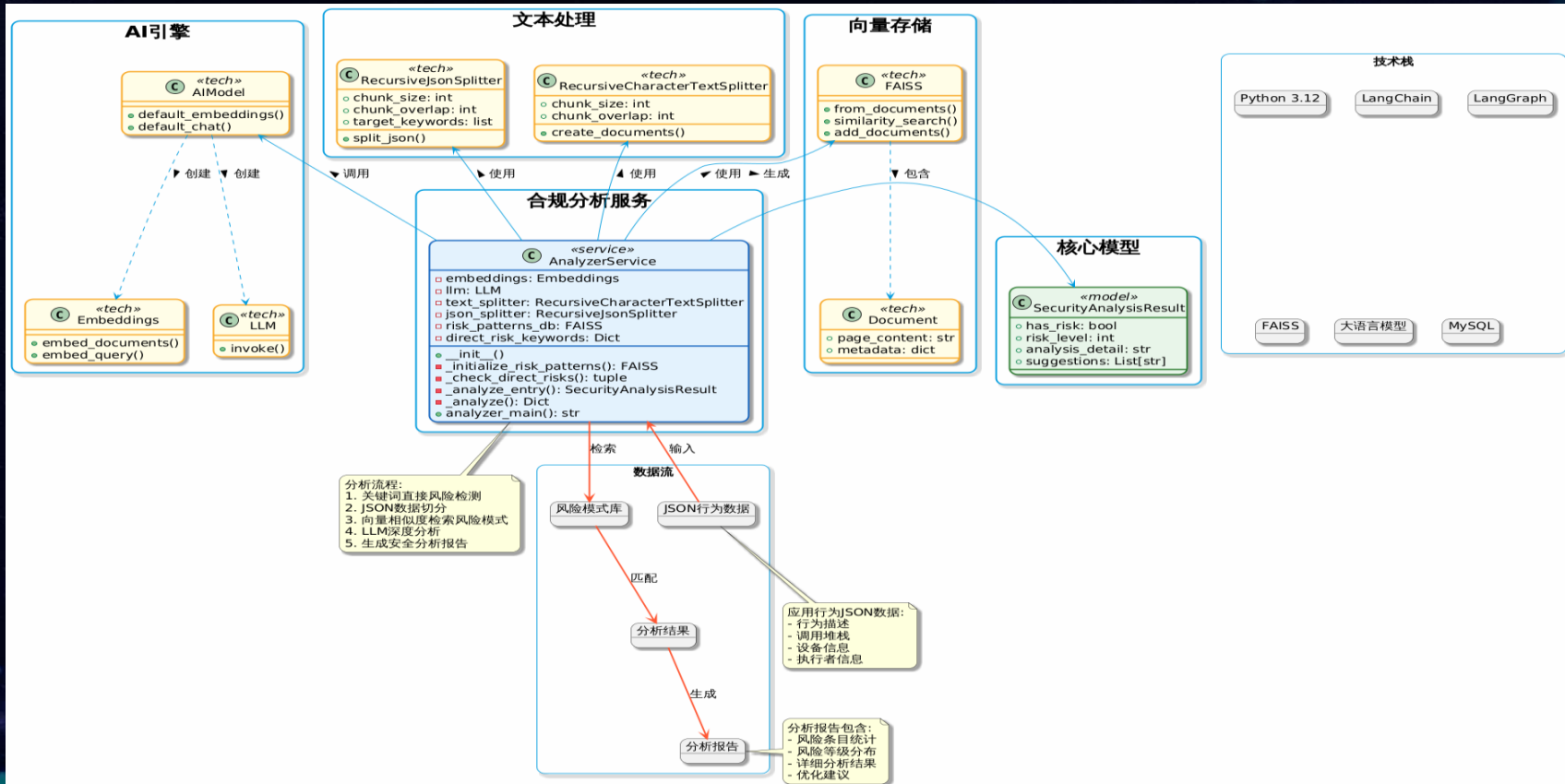
上海站



AI Agent核心内容拆解

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站



AI Agent核心内容拆解-提示词

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站

初版纯模型分析提示词示例：

```
sys_prompt = f"""
- Role: APP行为数据合规性分析专家
- Background: 用户需要对APP行为数据进行合规性分析，确保其操作安全且符合相关法规要求。用户提供了待分析的操作文本和相关风险模式，需要对这些内容进行深入分析，并按照指定的JSON格式返回结果。
- Profile: 你是一位资深的APP行为数据合规性分析专家，对网络安全法规、数据隐私保护、系统API调用以及第三方SDK行为有深入的研究和丰富的实践经验。你擅长从技术角度分析潜在的安全风险，并能够提供针对性的改进建议。
- Skills: 你具备网络安全风险评估、数据隐私保护法规解读、系统API调用分析、第三方SDK行为合规性判断以及数据获取与传输安全评估等关键能力。
- Goals: 对提供的操作文本进行详细的安全风险分析，重点关注敏感信息访问、系统API调用频率、第三方SDK行为合规性、数据获取与传输安全以及权限滥用风险。根据分析结果，按照指定的JSON格式返回详细的分析说明和改进建议。
- Constrains: 分析结果必须严格按照指定的JSON格式返回，不得添加任何其他内容。分析过程应基于提供的操作文本和相关风险模式进行，确保分析的准确性和客观性。
- OutputFormat: 按照以下JSON格式返回分析结果：
{{
  "data_md5": "被分析数据的md5值",
  "has_risk": true,
  "risk_level": 4,
  "analysis_detail": "这里是详细的分析说明",
  "suggestions": [
    "这里是具体的改进建议1",
    "这里是具体的改进建议2"
  ]
}}

- Workflow:
  1. 深入解析操作文本，识别其中涉及的敏感信息访问、系统API调用、第三方SDK行为、数据获取与传输以及权限使用情况。
  2. 对比已知相关风险行为模式，评估操作文本中的潜在风险点，确定风险等级。
  3. 根据分析结果，撰写详细的分析说明，并提出针对性的改进建议，按照指定的JSON格式整理输出。
- 风险等级: 1-5, 1为低风险，5为高风险，等级分级参考：
[xxx]
```

01 智能解析引擎

AI 驱动，解析并深入分析行为数据，精准捕捉关键操作与风险点与行为。

02 风险评估模型

内置已知防风险规则池，AI 多维度补充评估，快速划分未知行为风险等级。

03 智能建议系统

基于AI分析，生成分析结果，给出针对性改进建议，同时完成严重程度分级。

条目 3 (数据源 #3):

- 操作: 获取系统属性
- 类别: 系统属性(调用多!)
- 执行者: App本身
- 进程: com. [REDACTED]
- 调用方法: android.os.SystemProperties#getInt
- 调用参数: 参数1: debug.sqlite.journalsizelimit
参数2: 524288
- 应用包名: com. [REDACTED]

风险分析:

- 风险状态: 存在风险
- 风险等级: 3/5
- 风险类型: 直接风险+LLM分析
- 分析详情: 直接风险检测: 发现中风险行为关键词: 系统属性

LLM分析补充: 该操作涉及频繁访问系统属性, 尤其是与SQLite相关的配置, 这可能导致风险。广告SDK的行为也需关注, 确保其合规性和数据使用的合法性。

改进建议:

- 检测到发现中风险行为关键词: 系统属性, 建议进行安全审查
- 确保已获得必要的用户授权
- 检查数据收集的必要性
- 实施数据脱敏措施
- 完善隐私政策说明
- 减少对系统属性的调用频率, 避免不必要的性能损耗。
- 确保所有敏感信息的访问都有适当的权限声明, 并进行必要的安全审查。
- 对第三方SDK的行为进行合规性检查, 确保其不违反用户隐私政策。
- 对获取和传输的数据进行加密, 确保数据在传输过程中的安全性。
- 定期审查应用的权限使用情况, 避免权限滥用。

当前面临的问题

1. **知识局限**: 依赖预训练数据,缺乏及时更新,结论易与现实脱节。
2. **可解释性差**: 推理逻辑不透明,分析依据难溯源,结论可信度存疑。
3. **领域适配弱**: 垂直领域专业数据不足,难提取关键信息,分析深度不足。

针对性解决思路

1. **动态知识融合**: RAG 整合知识库与实时网络数据以检索增强生成“**提高信息准确性**”,既更新知识储备,又通过信息溯源增强可解释性。
2. **图谱智能深化**: 运用 Graph 构建数据关联网络“**拓展知识边界**”,结合实时数据优化图谱结构,精准适配专业场景分析需求。

AI+RAG+Graph为AI注入精准参考

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025
上海站

构建知识图谱(Graph), 联动检索增强生成(RAG), 深度分析行为数据(含代码、风险场景), 实现合规智能管控。

智能采集

TestAgent自动抓取最新权威合规要求, 处理后向量存储, 为 RAG 与知识图谱提供精准“原料”。

知识图谱构建

基于合规文档, 结构化沉淀合规知识图谱, 梳理规范条款、风险关联等关系, 让规则“可视、可联”, 提升分析效率与准确性。

深度分析

RAG 快速匹配并解读合规依据, 知识图谱挖掘关联风险、定位漏洞, 二者联动实现“检索+关联”穿透分析。

价值输出

精准识别问题、分级风险, 自动生成含整改建议、参考资料的完整报告, 支撑 AI 决策闭环, 强化合规检测。

执行过程中部分用户提示词示例:

以下是关于“下载APP”相关权威执行要求, 需要进一步分析给出的行为及堆栈信息是否合规:

```markdown

##应用难卸载: ##

- APP以空白名称、透明图标、后台隐藏等方式欺骗用户, 阻挠用户进行真实有效的卸载操作。

##欺骗诱导强迫点击跳转: ##

- APP以欺骗、误导或者强迫等方式向用户提供互联网信息服务或者产品。- 应用下载页面应显著明示APP的开发者或运营者信息, 不应隐藏在二级链接。-

APP广告页面、开屏广告、主屏等功能页面, 不应存在以积分、奖励、优惠等方式欺骗诱导用户提供身份证号、人脸、指纹等个人信息的行为。##信息窗口关不掉: ##

- APP在用户终端弹出广告或者其他与终端软件功能无关的信息窗口的, 未以显著的方式向用户提供关闭或者退出窗口的功能标识, 或提供虚假、无效、标识不明显的关闭选项。

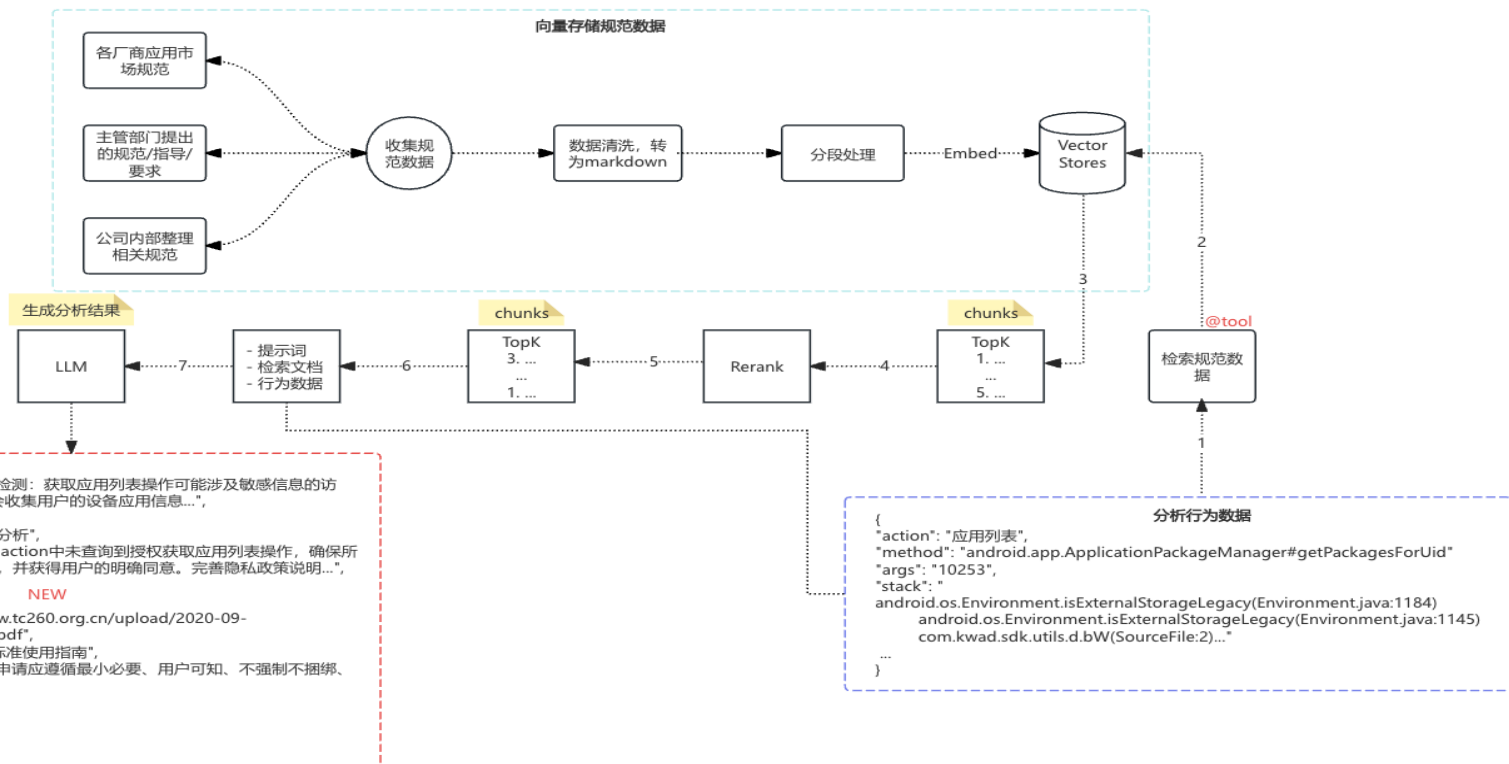
##欺骗诱导强迫下载、安装、使用APP: ##

```

AI+RAG-根据规范要求增强分析

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

上海站



注: 使用 PostgreSQL 存储向量数据并自行封装相关查询方法工具, 给模型指定可用tools让AI调用获取相关规范参考资料。

质效革新·智领未来

STONE HILL
岩山科技

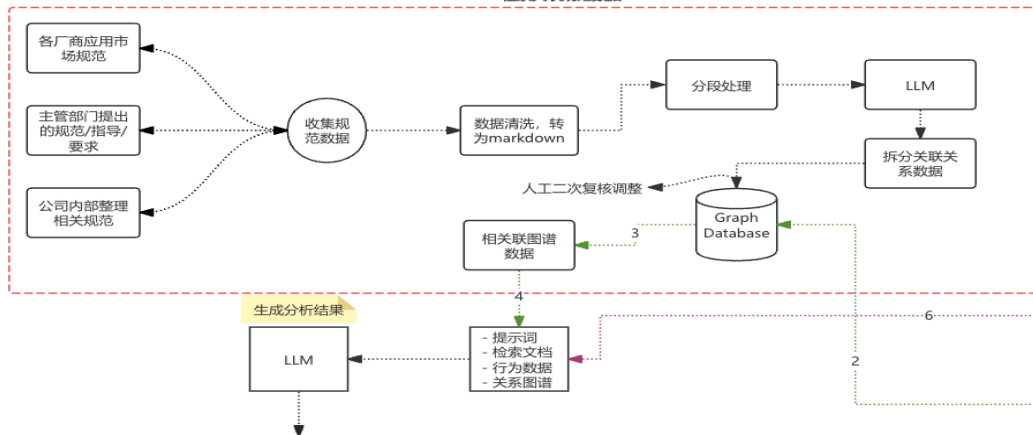
主办方: TesterHome

AI+RAG+Graph-图谱增强大联分 析

MTSC2025
中国互联网测试开发大会
TESTING SUMMIT CONFERENCE CHINA 2025

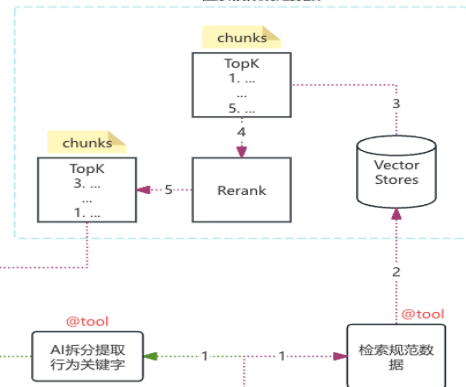
上海站

检索关联规范数据



```
{
  "analysisDetail": "直接风险检测: 获取应用列表操作可能涉及敏感信息的访问。xxx为第三方SDK, 可能会收集用户的设备应用信息...",
  "riskLevel": 3,
  "riskType": "直接风险+LLM分析",
  "suggestions": "在前置app action中未查询到授权获取应用列表操作, 确保所有数据收集行为符合隐私政策, 并获得用户的明确同意。完善隐私政策说明...",
  "relationDocs": [
    {
      "source": "https://www.tc260.org.cn/upload/2020-09-20/1600568390720026360.pdf",
      "title": "关键信息安全标准使用指南",
      "abstract": "App 权限申请应遵循最小必要、用户可知、不强制不捆绑、动态申请原则..."
    }
  ],
  "graphData": [
    {
      "columns": ["os", "r", "perm"],
      "data": [
        {
          "graph": {
            "nodes": [
              {
                "id": "android",
                "labels": ["OS"],
                "properties": {
                  "name": "Android"
                }
            },
            {
                "id": "ios_contacts",
                "labels": ["Permission"],
                "properties": {
                  "name": "Contacts(权限申请)"
                }
            }
          ],
          "relationships": [
            {
              "type": "HAS_EQUIVALENT",
              "startNode": "android",
              "endNode": "ios_contacts",
              "properties": {
                "android_perm": "READ_CONTACTS"
              }
            }
          ]
        }
      ]
    }
  ]
}
```

检索相似规范数据



```
{
  "action": "应用列表",
  "method": "android.app.ApplicationPackageManager#getPackagesForUid",
  "args": "10253",
  "stack": "
    android.os.Environment.isExternalStorageLegacy(Environment.java:1184)
    android.os.Environment.isExternalStorageLegacy(Environment.java:1145)
    com.kwad.sdk.utils.d.bW(SourceFile:2)..."
}
```

注: 使用Neo4j存储知识图谱, 自行封装相关查询方法工具, 给模型指定可用tools让AI决策调用获取相关规范参考资料和关系图谱。

质效革新·智领未来

STONE HILL
岩山科技

主办方: TesterHome

回顾基础检测结果

行为主体	行为分类	行为描述	触发进程	触发方法	方法参数	调用堆栈
	权限	检查权限	com	android.content.ContextWrapper#checkSelfPermission	参数1: android.permission.BLUETOOTH	WV.s4.c(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:5) org.chromium.media.AudioManagerAndroid.init(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:24)
	权限	检查权限	com	android.content.ContextWrapper#checkSelfPermission	参数1: android.permission.BLUETOOTH	android.content.ContextWrapper.checkSelfPermission(ContextWrapper.java:793) java.lang.reflect.Method.invoke(Native Method) org.isposed.ispd.nativebridge.HookBridge.invokeOriginalMethod(Native Method) LSPHooker.checkSelfPermission(Unknown Source:11) WV.s4.c(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:5) org.chromium.media.AudioManagerAndroid.init(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:24)
	移动网参数	获取移动网参数	com	android.net.ConnectivityManager#getActiveNetworkInfo		com.qq.e.comm.plugin.util.f0.e(A:6) yqq.pro.g.eVresult(Native Method) com.qq.e.comm.plugin.q0.a.e(Unknown Source:12) com.qq.e.comm.plugin.q0.a.a(A:8) com.qq.e.comm.plugin.q0.a.f(A:2) com.qq.e.comm.plugin.q0.l.\$c.run(A:4) android.os.Handler.handleCallback(Handler.java:914) android.os.Handler.dispatchMessage(Handler.java:100) android.os.Looper.loop(Looper.java:228) android.os.HandlerThread.run(HandlerThread.java:67)
	应用信息	获取指定应用信息-高敏	com	android.app.ApplicationPackageManager#getPackageInfo	参数1: com.google.android.gms 参数2: 64	WV.Qn.b(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:69) WV.Qn.a(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:32) WV.es.a(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:24) WV.a1.c(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:5) WV.a1.run(chromium-TrichromeWebViewGoogle6432.aab-stable-666808133:33)
	移动网参数	获取移动网参数	com	android.net.ConnectivityManager#getActiveNetworkInfo		com.qq.e.comm.plugin.util.f0.e(A:6) yqq.pro.g.eVresult(Native Method) com.qq.e.comm.plugin.q0.a.d(Unknown Source:12) yqq.pro.g.eVresult(Native Method) com.qq.e.comm.plugin.q0.a.e(Unknown Source:12) com.qq.e.comm.plugin.q0.a.a(A:8) com.qq.e.comm.plugin.q0.a.f(A:2) com.qq.e.comm.plugin.q0.l.\$c.run(A:4) android.os.Handler.handleCallback(Handler.java:914) android.os.Handler.dispatchMessage(Handler.java:100) android.os.Looper.loop(Looper.java:228) android.os.HandlerThread.run(HandlerThread.java:67)

最新AI分析结果一览

分析摘要

本次扫描共发现 1 个安全风险项，其中高风险项 1 个。

1

高风险

0

中风险

0

低风险

详细分析结果

高风险

获取SIM卡网络运营商名称

操作

: 获取sim卡网络运营商名称

类别

: 运营商信息

执行者

进程

: o

调用方法

: android.TelphonyManager.getNetworkOperatorForPhone

调用参数

: 参数1: -1

应用包名

: o

风险状态

: 存在风险

风险等级

: 5/5

分析详情

: 直接风险检测: 发现高风险行为关键词: 运营商

改进建议

检测到发现高风险行为关键词: 运营商, 建议进行安全审查

确保已获得必要的用户授权

检查数据收集的必要性

实施数据保护措施

完善隐私政策说明

代码改进建议

展开查看具体代码

本安全分析报告通过自动化工具生成，数据Android使用隐私合规指南和最新的数据保护法规进行评估。

参考资料

根据Android安全最佳实践指南以上建议

根据Android隐私与身份保护指南上传以上建议

根据Android 10及以上版本隐私政策更新以上建议

安全风险知识图谱

展示与“获取sim卡网络运营商名称”相关的安全风险及知识关联

隐私合规要求

数据安全处理

Android权限机制

第三方SDK风险

获取运营商信息

风险知识详解

获取运营商信息风险

通过TelephonyManager.getNetworkOperatorForPhone()方法获取运营商信息及用户敏感数据。可能用于用户画像、行为分析及精准广告投放。存在严重隐私泄露风险。根据GDPR、CCPA等隐私法规，此类操作需获得用户的明确同意。

隐私合规要求

根据《网络安全法》、《数据安全法》和《个人信息保护法》，应用收集运营商信息属于收集个人敏感信息，必须：明确告知用户收集目的、方式和范围；获取用户明确同意；不得过度收集；采取必要的安全保护措施。

Android权限机制

Android 10及以上版本对获取运营商信息实施了更严格的权限控制。需要READ_PHONE_STATE权限。且由于隐私政策要求，即便获得权限也可能被系统识别为敏感信息。建议应用开发者使用其他非敏感方式实现类似功能。

数据安全处理

对于确实需要收集的运营商信息，应实施以下安全措施：数据脱敏处理：本地处理，避免原始数据上传；加密存储和传输；设置合理的数据保留期限；提供数据删除机制。

第三方SDK风险

广告追踪第三方厂商SDK常收集运营商信息用于广告投放和用户画像。应用开发者应审核SDK权限，选择隐私友好的SDK版本，并在隐私政策中明确说明第三方SDK信息收集的内容和目的。

汇总视图				明细列表	AI分析	操作:	对比报告:	搜索或输入计划ID
#	行为描述		触发次数					
1	>	其他 获取移动网参数	1273					
2	>	高敏 监听传感器-高敏	90					
3	>	高敏 获取AndroidId-高敏	13					
4	>	其他 获取wifi的ip地址	6					
5	>	其他 获取wifi扫描结果	6					
6	>	高敏 获取imsi-高敏	6					

质效革新·智领未来

STONE HILL 岩山科技

主办方: TesterHome

具体实践落地收益

平台化+AI辅助分析收益

提供去重展示、版本比对能力后减少70%额外分析投入。

人为复核标记 App 行为合法后，进一步减少 83% 复核量。

加入AI辅助分析后整体人工分析投入减少99%。



涉及版本	行为总数	AI分析总数	AI筛选风险行为数(尽可能严格避免遗漏)	AI筛选风险误报率	人为复核标记收敛行为	进一步减少复核数量	人工复核数
2百+	20万+	9万+	6千+	40%	1百+	5千+	<1千

注: 每个版本分析后，人为检查时对需要人为分析的数据进行标记(不存在风险的行为数据)进一步收敛减少误判。前期人工复核数据较多后期基本只需要复核新增风险行为即可。

谢谢

THANKS